

CUADERNILLO DE ESTUDIO

CLASE 12

*“Factor humano y gestión de incidentes:
Junta de Crisis”*

✗ Incluye simulación de filtración de datos

Profesor: Mg. Ing. Rodrigo Atilio Elgueta

Unidad: Unidad 4

Datos del/la estudiante

Nombre y apellido: _____

Grupo N.º: _____

Negocio Digital (TP): _____

Fecha: _____

Índice

1. El factor humano: el eslabón más débil y el más fuerte	2
1.1. ¿Por qué las personas son críticas en seguridad?	2
1.2. Programas de concientización y capacitación	3
2. Gestión de incidentes de seguridad	4
2.1. El ciclo de vida de un incidente	4
2.2. Las 4 fases en detalle	4
3. Los 4 roles de la Junta de Crisis	5
3.1. Resumen de roles	5
3.2. Tarjetas de rol	6
4. La simulación: Junta de Crisis	8
4.1. Escenario inicial: “DataShop”	8
4.2. Cronograma de la simulación y puntos de inyección	9
5. Plantillas de respuesta por rol	10
5.1. Plantilla del Gerente General	10
5.2. Plantilla del Legal / Cumplimiento	11
5.3. Plantilla de Comunicaciones	12
5.4. Plantilla de TI / Seguridad	13
6. Debrief y lecciones aprendidas	14
7. Glosario de la Clase 12	15
8. Espacio para notas y preparación	15

1. El factor humano: el eslabón más débil y el más fuerte

En la Clase 3 vimos que el **phishing**, el **ransomware** y la **ingeniería social** son las amenazas más comunes para los negocios digitales. En la Clase 10, practicamos cómo diseñar campañas de concientización. Hoy vamos a ver cómo **todo eso se pone a prueba** cuando las cosas salen mal.

Definición

El **factor humano** se refiere al rol de las personas dentro del ecosistema de seguridad de una organización. Los empleados son simultáneamente:

- **El eslabón más débil:** un clic en un enlace de phishing puede comprometer toda la organización.
- **La primera línea de defensa:** un empleado bien capacitado puede detectar y reportar un ataque antes de que cause daño.

1.1 ¿Por qué las personas son críticas en seguridad?

Realidad	Implicancia
95 % de los incidentes de seguridad tienen un componente humano (error, negligencia, manipulación)	Ninguna tecnología por sí sola puede proteger si las personas no saben cómo actuar.
Los atacantes prefieren el camino más fácil: engañar a una persona en lugar de hackear un sistema	La ingeniería social es más barata y efectiva que el hacking técnico.
Las políticas y controles existen, pero requieren que las personas las cumplan	Una PSA (Clase 11) no sirve si nadie la conoce o no hay capacitación.

La conexión con lo anterior

- **Clase 10:** las campañas de concientización y los simulacros de phishing son **controles humanos** que reducen la probabilidad de incidentes.
- **Clase 11:** la PSA y el gobierno de la seguridad definen las **reglas del juego** que las personas deben seguir.
- **Clase 12 (hoy):** cuando todo lo anterior falla y ocurre un incidente real, la organización necesita un **proceso de respuesta** y personas capacitadas para ejecutarlo.

1.2 Programas de concientización y capacitación

Un programa efectivo de concientización no es un evento único (“una charla de una hora al año”). Es un **proceso continuo** que incluye:

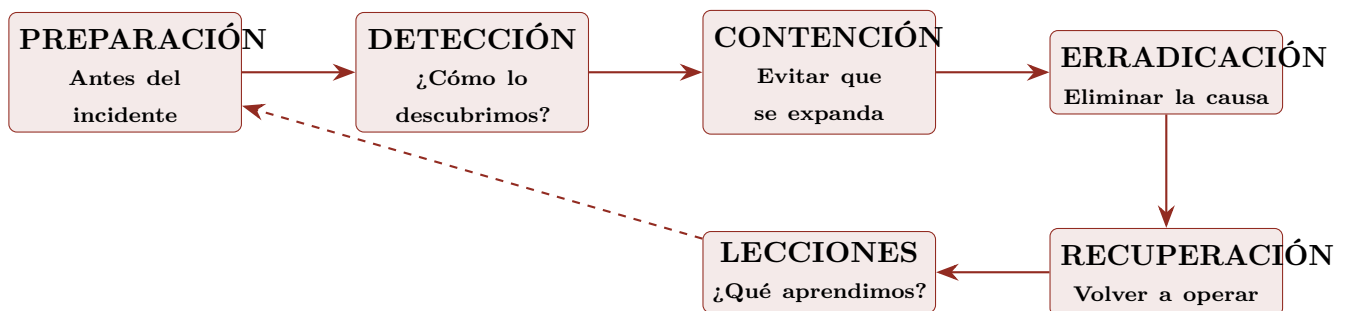
- **Capacitación inicial** al ingreso (PSA, políticas, expectativas).
- **Actualizaciones periódicas** (mensuales o trimestrales).
- **Simulacros de phishing** (Clase 10) para medir efectividad.
- **Micro-learning:** videos cortos, infografías, casos reales.
- **Métricas:** tasa de reporte de phishing, tiempo de respuesta, incidentes evitados.

2. Gestión de incidentes de seguridad

Definición

Un **incidente de seguridad** es cualquier evento que compromete la confidencialidad, integridad o disponibilidad de los activos de información. La **gestión de incidentes** es el proceso estructurado para detectarlos, contenerlos, erradicarlos, recuperar la normalidad y aprender de lo ocurrido.

2.1 El ciclo de vida de un incidente



2.2 Las 4 fases en detalle

Fase	¿Qué se hace?	¿Quién lidera?
Detección	Identificar el incidente, evaluar su alcance y severidad.	TI / Seguridad
Respuesta	Contener el daño, erradicar la amenaza, preservar evidencia.	TI / Seguridad + Legal
Comunicación	Informar a empleados, clientes, reguladores, medios.	Comunicaciones + Legal
Recuperación	Restaurar sistemas, monitorear, aprender del incidente.	Todos los roles

La diferencia entre un incidente y una crisis

Un **incidente** es un evento de seguridad que puede ser manejado por el equipo operativo. Una **crisis** es un incidente que **escala**: afecta la reputación, requiere comunicación externa, involucra a reguladores o tiene impacto financiero significativo. Hoy vamos a simular una **crisis**.

3. Los 4 roles de la Junta de Crisis

En la simulación de hoy, cada integrante del grupo asumirá uno de estos roles. Cada rol tiene responsabilidades específicas y debe tomar decisiones bajo presión de tiempo.

3.1 Resumen de roles

Rol	Responsabilidad principal
Gerencia General	Toma las decisiones estratégicas finales. Aprueba presupuesto de emergencia. Decide el nivel de comunicación pública.
Legal / Cumplimiento	Asegura el cumplimiento normativo (Ley 25.326, GDPR). Evalúa responsabilidades legales. Coordina con abogados externos.
Comunicaciones	Gestiona la comunicación interna y externa. Redacta comunicados. Maneja redes sociales y prensa.
TI / Seguridad	Contiene técnicamente el incidente. Coordina la investigación forense. Restaura sistemas.

3.2 Tarjetas de rol

Cada estudiante debe recibir (o recortar) una tarjeta de rol antes de comenzar la simulación.

Tu misión: Proteger el negocio a largo plazo.

Tus decisiones clave:

- ¿Cuánto presupuesto de emergencia aprobás para contener el incidente?
- ¿Notificamos a los clientes ahora o esperamos a tener más información?
- ¿Hacemos declaración pública o esperamos a que la prensa nos contacte?
- ¿Contratamos un equipo forense externo?

Tu pregunta recurrente: “¿Cuál es el impacto financiero y reputacional de cada opción?”

Tu misión: Minimizar la responsabilidad legal y cumplir la ley.

Tus decisiones clave:

- ¿Cuándo hay que notificar a la AAIP (Agencia de Acceso a la Información Pública)?
- ¿La Ley 25.326 exige notificación a los titulares de los datos?
- ¿Hay clientes en Europa? ¿Aplica el GDPR?
- ¿Qué evidencias hay que preservar para una eventual investigación judicial?

Tu pregunta recurrente: “¿Qué dice la ley y cuáles son los plazos?”

Tu misión: Proteger la reputación y la confianza de los clientes.

Tus decisiones clave:

- ¿Qué decimos en el comunicado interno a los empleados?
- ¿Qué decimos en el comunicado externo a los clientes?
- ¿Cómo respondemos si la prensa nos contacta?
- ¿Publicamos algo en redes sociales antes de que se viralice?

Tu pregunta recurrente: “¿Qué van a pensar los clientes y cómo van a reaccionar?”

Tu misión: Contener técnicamente el incidente y restaurar la operación.

Tus decisiones clave:

- ¿Desconectamos el servidor afectado de la red?
- ¿Apagamos los sistemas comprometidos o los aislamos?

- ¿Preservamos evidencia forense (logs, imágenes de disco)?
- ¿Cuánto tiempo estimamos para restaurar la operación normal?

Tu pregunta recurrente: “¿Cuál es el alcance técnico del incidente y cómo evitamos que se expanda?”

4. La simulación: Junta de Crisis

Duración total: 75 minutos de simulación + 15 minutos de debrief.

Mecánica:

1. El docente presenta el escenario inicial (la “bomba” cae).
2. Cada grupo se reúne como Junta de Crisis y trabaja en tiempo real.
3. El docente introduce **puntos de inyección** (eventos sorpresa) en momentos específicos para forzar decisiones.
4. Cada grupo completa las plantillas de respuesta de su rol.
5. Al final, cada grupo presenta sus decisiones y se hace el debrief.

4.1 Escenario inicial: “DataShop”

Contexto: “DataShop” es un e-commerce de electrónica con programa de fidelidad. Tiene 8.000 clientes activos y una base de datos con nombres, emails, teléfonos e historial de compras.

Lunes 9:15 AM: El equipo de TI detecta tráfico de salida inusual desde el servidor de la base de datos.

Investigación inicial (9:15-9:30):

- La base de datos de clientes fue accedida desde una IP externa.
- Se encontró un archivo ejecutable sospechoso en la PC de un empleado del área de Finanzas.
- El empleado recuerda haber abierto un adjunto en un email que parecía ser de un proveedor.
- El adjunto instaló software de acceso remoto.

Datos potencialmente comprometidos:

- Nombres, emails, teléfonos, historial de compras (8.000 clientes).
- Datos de pago (cifrados, pero no se sabe si la clave de cifrado fue comprometida).

Situación adicional: Un foro de hackers publicó una muestra de datos de DataShop y el atacante está exigiendo un rescate.

4.2 Cronograma de la simulación y puntos de inyección

La simulación se desarrolla en tiempo real. El docente introduce **puntos de inyección** (eventos sorpresa) en los momentos indicados para forzar decisiones.

Tiempo	Evento / Punto de inyección
T = 0 min	Se presenta el escenario inicial. La Junta de Crisis se reúne.
T = 10 min	Inyección 1: Un periodista envía un email preguntando si DataShop sufrió una filtración de datos.
T = 25 min	Inyección 2: Un cliente publica en redes sociales que recibió un email sospechoso a nombre de DataShop.
T = 40 min	Inyección 3: El atacante envía una nota de rescate con un plazo de 48 horas para pagar.
T = 55 min	Inyección 4: La AAIP envía una notificación solicitando información sobre una posible brecha de datos.
T = 70 min	Cierre de la simulación. Cada grupo presenta sus decisiones finales.
T = 75-90 min	Debrief grupal: ¿qué funcionó, qué no, qué aprendimos?

5. Plantillas de respuesta por rol

Durante la simulación, cada rol debe completar estas plantillas. Al final, se presentan al docente y al resto de la clase.

5.1 Plantilla del Gerente General

Decisión 1: Presupuesto de emergencia

?Cuánto presupuesto aprueban para contener el incidente? (forense externo, consultoría legal, etc.)

Decisión 2: Notificación a clientes

?Notificamos a los 8.000 clientes ahora o esperamos? Justificación:

Decisión 3: Comunicación pública

?Hacemos declaración pública proactiva o esperamos a que la prensa nos contacte? Justificación:

Decisión 4: Rescate

?Pagamos el rescate al atacante? ?Por qué sí o por qué no? (Considerar implicancias legales y éticas):

5.2 Plantilla del Legal / Cumplimiento

Cuestión 1: Obligación de notificación a la AAIP

?Qué dice la Ley 25.326 sobre la notificación de brechas de datos? ?Cuál es el plazo?

Cuestión 2: Notificación a los titulares de datos

?Los 8.000 clientes deben ser notificados? ?Qué tipo de datos se vieron comprometidos?

Cuestión 3: Aplicabilidad del GDPR

?Hay clientes en Europa? ?Aplica el GDPR? ?Hay obligaciones adicionales?

Cuestión 4: Preservación de evidencia

?Qué evidencias deben preservarse para una eventual investigación judicial?

5.3 Plantilla de Comunicaciones

Comunicado interno a empleados

Redacten el comunicado interno (2-3 párrafos):

Comunicado externo a clientes

Redacten el comunicado externo (2-3 párrafos):

Respuesta a prensa

Redacten una respuesta de 2-3 oraciones para el periodista que envió el email:

Redes sociales

?Publican algo en redes sociales antes de que se viralice? ?Qué y cuándo?

5.4 Plantilla de TI / Seguridad

Acción 1: Contención inmediata

?Desconectan el servidor afectado de la red? ?Apagan los sistemas comprometidos?
Justifiquen:

Acción 2: Preservación de evidencia

?Qué evidencias técnicas deben preservar? (logs, imágenes de disco, capturas de red):

Acción 3: Análisis forense

?Contratan un equipo forense externo? ?Qué esperan que determinen?

Acción 4: Restauración

?Cuánto tiempo estiman para restaurar la operación normal? ?Qué sistemas se restauran primero?

6. Debrief y lecciones aprendidas

Al final de la simulación, cada grupo presenta sus decisiones y se hace un debrief grupal. Este es el momento de reflexionar sobre lo que funcionó, lo que no, y qué habrían hecho diferente.

Respondan como grupo:

1. ¿Qué decisión fue la más difícil de tomar? ¿Por qué?

2. ¿Qué rol tuvo más presión durante la simulación? ¿Cómo lo manejaron?

3. ¿Qué habrían hecho diferente si hubieran tenido más tiempo o más información?

4. ¿Qué elemento de la PSA (Clase 11) habría ayudado a prevenir o manejar mejor esta crisis?

5. ¿Qué incluirían en su Plan de Respuesta a Incidentes del TP Integrador a partir de esta experiencia?

Conexión con el TP Integrador

Lo que aprendan hoy en la Junta de Crisis es el **insumo directo** para el Entregable 6 del TP Integrador: **Plan de respuesta a incidentes y de continuidad de negocio**. Cada decisión que tomaron hoy es una pieza de ese plan. Guarden las plantillas completadas.

7. Glosario de la Clase 12

Término	Definición en una línea
Incidente de seguridad	Evento que compromete la CID de los activos de información.
Crisis	Incidente que escala y requiere comunicación externa o tiene impacto significativo.
Junta de Crisis	Equipo multidisciplinario que gestiona la respuesta a un incidente grave.
Detección	Fase de identificación del incidente.
Contención	Fase de limitar el daño y evitar que el incidente se expanda.
Erradicación	Fase de eliminar la causa raíz del incidente.
Recuperación	Fase de restaurar la operación normal.
Lecciones aprendidas	Análisis posterior al incidente para mejorar futuros procesos.
Concientización	Capacitación para que las personas reconozcan y eviten amenazas.
Inyección	Evento sorpresa introducido durante una simulación para forzar decisiones.

8. Espacio para notas y preparación

Usá este espacio para anotar decisiones clave de la simulación, ideas para tu Plan de Respuesta a Incidentes del TP, o dudas sobre la gestión de crisis.